

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 29

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM8-001)

Which activity is MOST characteristic of information security governance?

- A. Investigating individual alerts and updating incident tickets
- B. Setting direction, assigning accountability, and evaluating security outcomes
- C. Installing security software on employee devices
- D. Performing daily access administration

Question 2 (CISM8-002)

Scenario: A technology company's innovation labs can launch experiments within days. Teams avoid security review because the standard process was designed for long production projects.

What should the information security manager recommend FIRST?

- A. Require full production approval for every short-lived experiment.
- B. Exempt all experiments from security requirements.
- C. Transfer accountability for experiments to external hosting providers.
- D. Create risk-tiered guardrails, delegated authority, and escalation criteria for experimentation.

Question 3 (CISM8-003)

Scenario: An engineering consortium handles information subject to hypothetical jurisdictional transfer restrictions and customer confidentiality terms. Teams share files through several partner platforms without a common approval process.

What is the BEST governance response?

- A. Prohibit every external information exchange regardless of business need.
- B. Allow each engineer to interpret the restrictions independently.
- C. Map restrictions to information categories and flows, then assign approval and monitoring responsibilities.
- D. Assume customer confidentiality terms replace jurisdictional requirements.

Question 4 (CISM8-004)

What does decision authority define in information security governance?

- A. Who performs every technical task
- B. Who independently audits all management decisions
- C. Who is empowered to make a specified decision within established limits
- D. Who supplies the technology used to implement a decision

Question 5 (CISM8-005)

Scenario: The executive responsible for a digital marketplace also approves its security exceptions and chairs the forum that independently evaluates whether marketplace risk is acceptable.

What is the GREATEST governance concern?

- A. The same executive influences delivery, exception approval, and independent evaluation of the resulting risk.
- B. The marketplace may have too many technical controls.
- C. The evaluation forum meets more frequently than the board.
- D. Business executives participate in security decisions.

Question 6 (CISM8-006)

Scenario: An automotive services firm is designing a partner ecosystem that will expose customer and vehicle services through shared interfaces. Business capabilities and information exchanges are still being defined.

How should the information security manager contribute now?

- A. Wait until partner interfaces are deployed and then test them.
- B. Require every partner to reproduce the firm's internal architecture.
- C. Select all partner technologies without input from service owners.
- D. Define risk, trust, information, and accountability requirements with business and architecture stakeholders.

Question 7 (CISM8-007)

Why should information security governance be integrated with enterprise architecture governance?

- A. To align security requirements with capabilities, processes, information, applications, and technology decisions
- B. To replace business objectives with technical design principles
- C. To prevent any change to established applications and technology
- D. To make enterprise architects accountable for every security outcome

Question 8 (CISM8-008)

Scenario: A travel company plans to move booking, customer identity, and loyalty processing to one provider. The proposal reduces cost but lacks tested exit assistance, data portability, and service transition obligations.

What should the information security manager recommend?

- A. Accept the proposal because cost reduction offsets concentration risk.
- B. Require concentration analysis and enforceable portability, transition, assurance, and exit provisions.
- C. Transfer business continuity accountability to the provider.
- D. Reject all consolidated service arrangements regardless of controls.

Question 9 (CISM8-009)

Scenario: A payroll supervisor can request, approve, provision, and certify the supervisor's own privileged access during peak processing periods.

Which change would MOST improve governance?

- A. Require independent approval and review, with controlled emergency access when necessary.
- B. Permit self-approval whenever payroll deadlines are near.
- C. Eliminate access records to reduce administrative effort.
- D. Grant permanent privileged access to avoid repeated requests.

Question 10 (CISM8-010)

Scenario: A hospitality group has accumulated security-related architecture exceptions across hotels. Some affect payment services, while others concern low-risk systems scheduled for replacement.

What is the BEST basis for prioritizing remediation?

- A. The alphabetical order of hotel names
- B. The number of pages in each exception request
- C. The seniority of the manager who reported each exception
- D. Business criticality, exposure, dependencies, target architecture, and remaining system life

Question 11 (CISM8-011)

Which statement is the BEST example of an information security strategic objective?

- A. Purchase three security technologies during the next budget cycle.
- B. Review system alerts at the end of each working day.
- C. Improve the resilience of critical customer services to remain within approved disruption tolerance.
- D. Create the longest possible set of security procedures.

Question 12 (CISM8-012)

Scenario: A medical logistics company expands through local delivery partners while customers begin requiring near-real-time shipment visibility.

Why should the information security strategy be reviewed?

- A. Only the customer requirement matters because partners are operational.
- B. Partner selection automatically transfers information risk.
- C. The review can wait until a partner causes a confirmed incident.
- D. New partners, information flows, availability expectations, and dependencies may change strategic capability needs.

Question 13 (CISM8-013)

Scenario: A nonprofit wants consistent classification of donor information. The current state has no named owners or common criteria, while the desired state requires accountable decisions throughout the information lifecycle.

What should the information security manager do NEXT?

- A. Define and prioritize initiatives for ownership, criteria, lifecycle processes, training, and enabling tools.
- B. Buy classification software before defining decision ownership.
- C. Let every department maintain permanent unrelated labels.
- D. Measure success solely by the number of files scanned.

Question 14 (CISM8-014)

Scenario: A federation of independent credit associations wants a common security governance framework, but members differ in size, services, and regulatory exposure.

What is the BEST implementation approach?

- A. Define common governance outcomes and tailor practices according to risk, obligations, and capability.
- B. Require identical detailed controls for every member regardless of context.
- C. Allow each member to use unrelated terminology and reporting.
- D. Adopt only practices that existing tools can automate.

Question 15 (CISM8-015)

Scenario: A construction company can fund one initiative: enterprise asset ownership needed by several roadmap projects, a new executive dashboard, or early replacement of a stable low-risk tool.

Which initiative should receive the HIGHEST priority?

- A. The dashboard because leadership will see immediate visual improvement
- B. Asset ownership because it enables dependent capabilities and more reliable risk decisions
- C. The tool replacement because procurement is already prepared
- D. Equal funding for all initiatives even if no deliverable can be completed

Question 16 (CISM8-016)

Scenario: The board approves a customer identity strategy, but business executives will not assign process owners or staff to redesign onboarding. The security team cannot deliver the outcome alone.

What is the PRIMARY governance issue?

- A. The strategy contains too few security products.
- B. Sponsorship has not produced accountable ownership and cross-functional resource commitments.
- C. Board approval makes business ownership unnecessary.
- D. The security team needs authority over every onboarding decision.

Question 17 (CISM8-017)

Scenario: An airline schedules automated access decisions before completing workforce identity records, role ownership, and application inventory.

How should the roadmap be changed?

- A. Remove role ownership because it is not a technology project.
- B. Deploy automation first because it will create accurate source information.
- C. Complete the foundational identity, ownership, and inventory capabilities before dependent automation.
- D. Run the initiatives independently without shared milestones.

Question 18 (CISM8-018)

Scenario: A pharmaceutical wholesaler wants critical suppliers to resolve material findings promptly. Its dashboard reports only the number of assessment questionnaires sent.

Which metric BEST indicates the desired outcome?

- A. The percentage of material supplier findings resolved within approved time limits
- B. The number of employees who can send questionnaires
- C. The number of questions in each assessment
- D. The amount spent on the assessment platform

Question 19 (CISM8-019)

Scenario: An insurance broker will exit two data centers within eighteen months. Security proposals request five-year renewals for separate tools used only in those facilities.

What should the information security manager recommend?

- A. Renew every tool for five years to avoid short-term change.
- B. Ignore the architecture timeline when evaluating security investments.
- C. Remove all data-center controls immediately.
- D. Fund necessary transition protection while prioritizing capabilities reusable in the target architecture.

Question 20 (CISM8-020)

Scenario: A port operator needs cloud governance skills within six months. Current staff understand operations, permanent hiring will take longer, and long-term accountability must remain internal.

What should the information security manager do?

- A. Delay all cloud initiatives until permanent hiring is complete.
- B. Transfer risk ownership to a consulting firm.
- C. Combine training, temporary expertise, internal ownership, and planned knowledge transfer.
- D. Purchase governance tools and eliminate the need for specialist knowledge.

Question 21 (CISM8-021)

What does enterprise risk appetite express?

- A. The amount and type of risk the enterprise is willing to pursue or retain in achieving objectives
- B. The number of risks that must appear in a register
- C. The exact configuration required for every control
- D. The authority of security staff to accept all business risk

Question 22 (CISM8-022)

Scenario: A regional bank compares three data protection programs. One is inexpensive but covers few critical processes, one is fast but creates difficult exit dependencies, and one costs more but supports the approved architecture and business priorities.

How should the information security manager guide selection?

- A. Select the program proposed by the largest department.
- B. Select the lowest initial price.
- C. Select the fastest implementation regardless of long-term dependency.
- D. Compare strategic outcomes, coverage, risk reduction, lifecycle cost, architecture fit, dependencies, and exit options.

Question 23 (CISM8-023)

Scenario: Factory leaders resist a security resilience program because presentations focus on technical components rather than production outcomes, required process changes, or decision ownership.

What should the information security manager do?

- A. Send more detailed network diagrams.
- B. Explain production risks, expected outcomes, responsibilities, dependencies, and decisions in operational terms.
- C. Exclude factory leaders from roadmap planning.
- D. Measure commitment only by attendance at security training.

Question 24 (CISM8-024)

Scenario: A consumer lending company completes every planned security project, but unauthorized exposure of customer records continues to increase. Reports emphasize schedule and budget performance.

What is the MOST appropriate conclusion?

- A. The strategy is effective because all projects were completed.
- B. Exposure measures should be removed from executive reporting.
- C. Strategic assumptions, initiatives, and outcome measures require review because delivered outputs are not reducing exposure.
- D. The same roadmap should be repeated with a larger budget.

Question 25 (CISM8-025)

Scenario: A company adopts a strategy based on business ownership of information risk, but its policy still states that the security department owns every security decision.

What is the PRIMARY concern?

- A. Policies should never assign decision responsibilities.
- B. The policy conflicts with the strategy and may reinforce incorrect accountability.
- C. The strategy must always be changed to match legacy policy.
- D. Only technical procedures need to align with strategy.

Question 26 (CISM8-026)

Scenario: A steering committee receives hundreds of operational statistics but cannot determine whether security investments support expansion or which risk decisions require leadership.

How should the information security manager revise the report?

- A. Add every raw alert generated by monitoring systems.
- B. Link outcome trends, material risk, investment performance, dependencies, and required decisions to enterprise objectives.
- C. Report only favorable projects.
- D. Remove strategic targets to shorten the report.

Question 27 (CISM8-027)

Scenario: A software company begins offering regulated financial services through acquired regional firms. The existing security strategy assumes unregulated products, centralized operations, and no branch infrastructure.

What should the information security manager do FIRST?

- A. Apply the existing strategy unchanged to maintain consistency.
- B. Purchase financial security technologies before defining the target state.
- C. Reassess objectives, obligations, stakeholders, architecture, risk appetite, capability gaps, and investment priorities.
- D. Delegate enterprise strategy to the acquired firms.

Answer Key

Domain I - Information Security Governance

1 B	2 D	3 C	4 C	5 A
6 D	7 A	8 B	9 A	10 D
11 C	12 D	13 A	14 A	15 B
16 B	17 C	18 A	19 D	20 C
21 A	22 D	23 B	24 C	25 B
26 B	27 C			

Detailed Explanations

Question 1 (CISM8-001)

Correct answer: B - Setting direction, assigning accountability, and evaluating security outcomes

Governance sets direction, establishes accountability, and evaluates whether outcomes support enterprise objectives. Alert investigation, software installation, and access administration are management or operational activities performed within that direction.

Question 2 (CISM8-002)

Correct answer: D - Create risk-tiered guardrails, delegated authority, and escalation criteria for experimentation.

Risk-tiered guardrails preserve rapid experimentation while establishing boundaries, accountability, and escalation for higher-risk work. Full production review may be disproportionate, blanket exemption creates unmanaged exposure, and providers do not assume the company's governance accountability.

Question 3 (CISM8-003)

Correct answer: C - Map restrictions to information categories and flows, then assign approval and monitoring responsibilities.

Mapping obligations to information and flows enables consistent authorization, safeguards, and oversight. A universal prohibition may prevent legitimate work, individual interpretation creates inconsistency, and contractual terms do not automatically replace applicable legal requirements.

Question 4 (CISM8-004)

Correct answer: C - Who is empowered to make a specified decision within established limits

Decision authority identifies who may make a defined decision and within what limits. Task performance, independent assurance, and technology supply are separate responsibilities that do not automatically confer governance authority.

Question 5 (CISM8-005)

Correct answer: A - The same executive influences delivery, exception approval, and independent evaluation of the resulting risk.

Combining delivery incentives, exception approval, and independent evaluation creates a conflict that can suppress objective risk oversight. Control volume and meeting frequency are secondary, while appropriate business participation is necessary when roles and checks are clearly defined.

Question 6 (CISM8-006)

Correct answer: D - Define risk, trust, information, and accountability requirements with business and architecture stakeholders.

Early governance of trust, information, risk, and accountability helps shape the ecosystem before designs become fixed. Post-deployment testing is too late for foundational choices, security should not select the whole solution alone, and partners may meet outcomes without copying internal architecture.

Question 7 (CISM8-007)

Correct answer: A - To align security requirements with capabilities, processes, information, applications, and technology decisions

Integration ensures security requirements support the connected business and technology decisions represented in enterprise architecture. Architects do not own every outcome, business objectives remain primary, and architecture governance enables controlled change rather than preventing it.

Question 8 (CISM8-008)

Correct answer: B - Require concentration analysis and enforceable portability, transition, assurance, and exit provisions.

The company should understand concentration exposure and establish enforceable mechanisms for assurance, portability, transition, and exit. Cost alone does not offset the risk, accountability remains with the company, and consolidation may be acceptable when governed appropriately.

Question 9 (CISM8-009)

Correct answer: A - Require independent approval and review, with controlled emergency access when necessary.

Independent approval and review separate incompatible duties while controlled emergency access supports time-sensitive operations. Deadlines do not justify self-approval, removing records destroys oversight, and permanent privileges expand exposure.

Question 10 (CISM8-010)

Correct answer: D - Business criticality, exposure, dependencies, target architecture, and remaining system life

Risk, business importance, dependencies, architecture direction, and lifecycle provide a defensible basis for treatment priority. Naming order, sponsor seniority, and document length do not indicate enterprise impact or remediation value.

Question 11 (CISM8-011)

Correct answer: C - Improve the resilience of critical customer services to remain within approved disruption tolerance.

The resilience statement defines a business and risk outcome connected to an approved boundary. Technology purchases and alert reviews are activities, while procedure length is not a meaningful strategic result.

Question 12 (CISM8-012)

Correct answer: D - New partners, information flows, availability expectations, and dependencies may change strategic capability needs.

The expansion changes stakeholders, data flows, service expectations, and third-party dependencies that the strategy must address. Partners remain a strategic influence, risk is not automatically transferred, and waiting for an incident would be reactive.

Question 13 (CISM8-013)

Correct answer: A - Define and prioritize initiatives for ownership, criteria, lifecycle processes, training, and enabling tools.

The gap requires governance, process, people, and enabling technology initiatives, not merely a product. Tool-first deployment may automate unclear decisions, unrelated labels prevent consistency, and scan volume does not demonstrate accountable classification.

Question 14 (CISM8-014)

Correct answer: A - Define common governance outcomes and tailor practices according to risk, obligations, and capability.

Common outcomes enable consolidated oversight, while tailoring respects differences in risk, obligations, and maturity. Uniform detailed controls may be disproportionate, unrelated models impede governance, and current tools should not determine strategic requirements.

Question 15 (CISM8-015)

Correct answer: B - Asset ownership because it enables dependent capabilities and more reliable risk decisions

Asset ownership is a foundational dependency that supports multiple capabilities and improves risk decisions. Visibility and procurement readiness are secondary, while fragmenting limited funding may prevent any initiative from producing value.

Question 16 (CISM8-016)

Correct answer: B - Sponsorship has not produced accountable ownership and cross-functional resource commitments.

Effective sponsorship must establish owners, resources, and decisions across affected functions. Additional products do not solve ownership, security should not control every business decision, and board approval alone does not execute process change.

Question 17 (CISM8-017)

Correct answer: C - Complete the foundational identity, ownership, and inventory capabilities before dependent automation.

Reliable source records, role ownership, and inventory are prerequisites for trustworthy automated decisions. Automation cannot manufacture governance context, role ownership is essential, and isolated initiatives increase integration and delivery risk.

Question 18 (CISM8-018)

Correct answer: A - The percentage of material supplier findings resolved within approved time limits

Timely resolution of material findings directly measures reduction of supplier exposure. Questionnaire size, user counts, and platform cost measure inputs or activities rather than the intended strategic outcome.

Question 19 (CISM8-019)

Correct answer: D - Fund necessary transition protection while prioritizing capabilities reusable in the target architecture.

The investment plan should manage interim risk without creating avoidable stranded cost and should favor target-state capabilities. Long renewals ignore lifecycle, immediate removal creates exposure, and architecture timing is essential to responsible investment.

Question 20 (CISM8-020)

Correct answer: C - Combine training, temporary expertise, internal ownership, and planned knowledge transfer.

A blended plan closes the immediate skill gap while building sustainable internal capability and preserving accountability. Full delay may obstruct business goals, consultants cannot own enterprise risk, and tools do not replace expertise.

Question 21 (CISM8-021)

Correct answer: A - The amount and type of risk the enterprise is willing to pursue or retain in achieving objectives

Risk appetite expresses the broad amount and type of risk the enterprise is willing to pursue or retain while achieving objectives. It is not a technical standard, a register quota, or a transfer of all acceptance authority to security personnel.

Question 22 (CISM8-022)

Correct answer: D - Compare strategic outcomes, coverage, risk reduction, lifecycle cost, architecture fit, dependencies, and exit options.

A sound business case compares enterprise outcomes and risk across the full lifecycle, including architecture and exit implications. Initial price, speed, or sponsor size alone can conceal material gaps and long-term exposure.

Question 23 (CISM8-023)

Correct answer: B - Explain production risks, expected outcomes, responsibilities, dependencies, and decisions in operational terms.

Operational leaders are more likely to commit when the strategy is connected to production risk, outcomes, ownership, and required decisions. More technical detail may deepen misunderstanding, exclusion weakens ownership, and training attendance alone does not demonstrate strategic commitment.

Question 24 (CISM8-024)

Correct answer: C - Strategic assumptions, initiatives, and outcome measures require review because delivered outputs are not reducing exposure.

Rising exposure despite completed projects shows that delivery outputs are not achieving the intended outcome. Removing the measure hides performance, and repeating the roadmap without analysis may reinforce ineffective investment.

Question 25 (CISM8-025)

Correct answer: B - The policy conflicts with the strategy and may reinforce incorrect accountability.

Policy should translate current strategic direction into consistent authority and accountability; conflicting language can prevent execution. Policies appropriately assign responsibilities, legacy policy should be updated when needed, and alignment extends beyond technical procedures.

Question 26 (CISM8-026)

Correct answer: B - Link outcome trends, material risk, investment performance, dependencies, and required decisions to enterprise objectives.

Decision-oriented reporting connects security outcomes, exposure, investments, dependencies, and required action to enterprise objectives. Raw alerts overwhelm governance audiences, favorable-only reporting is incomplete, and removing targets prevents evaluation.

Question 27 (CISM8-027)

Correct answer: C - Reassess objectives, obligations, stakeholders, architecture, risk appetite, capability gaps, and investment priorities.

The new services and operating model invalidate major assumptions and require integrated reassessment before priorities and investments are set. Reusing the old strategy preserves misalignment, purchasing is premature, and acquired firms contribute input without owning enterprise strategy.